

L2 MAC Flooding & ARP Spoofing

Task 1: Getting Started

Answer the questions below

I understand and have started the machine by pressing the Start Machine button.

No answer needed

✓ Correct Answer

Task 2: Initial Access

Answer the questions below

Now, can you (re)gain access? (Yay/Nay)

Yay

✓ Correct Answer [Hint](#)

Task 3: Network Discovery

Answer the questions below

What is your IP address?

192.168.12.66

✓ Correct Answer

What's the network's CIDR prefix?

/24

✓ Correct Answer [Hint](#)

How many other live hosts are there?

2

✓ Correct Answer

What's the hostname of the first host (lowest IP address) you've found?

alice

✓ Correct Answer [Hint](#)

Task 4: Passive Network Sniffing

Answer the questions below

Can you see any traffic from those hosts? (Yay/Nay)

Yay

✓ Correct Answer

Who keeps sending packets to eve?

Bob

✓ Correct Answer

What type of packets are sent?

ICMP

✓ Correct Answer [Hint](#)

What's the size of their data section? (bytes)

666

✓ Correct Answer [Hint](#)

Task 5: Sniffing while MAC Flooding

Answer the questions below

What kind of packets is Alice continuously sending to Bob?

ICMP

✓ Correct Answer

🔍 Hint

What's the size of their data section? (bytes)

1337

✓ Correct Answer

🔍 Hint

Task 6: Man-in-the-Middle: Intro to ARP Spoofing

Answer the questions below

Can ettercap establish a MITM in between Alice and Bob? (Yay/Nay)

Nay

✓ Correct Answer

Would you expect a different result when attacking hosts without ARP packet validation enabled? (Yay/Nay)

Yay

✓ Correct Answer

Task 7: Man-in-the-Middle: Sniffing

Answer the questions below

Scan the network on eth1. Who's there? Enter their IP addresses in ascending order.

192.168.12.10, 192.168.12.20

✓ Correct Answer

Which machine has an open well-known port?

192.168.12.20

✓ Correct Answer

What is the port number?

80

✓ Correct Answer

Can you access the content behind the service from your current position? (Nay/Yay)

Nay

✓ Correct Answer

Can you see any meaningful traffic to or from that port passively sniffing on you interface eth1? (Nay/Yay)

Nay

✓ Correct Answer

🔍 Hint

Now launch the same ARP spoofing attack as in the previous task. Can you see some interesting traffic, now? (Nay/Yay)

Yay

✓ Correct Answer

🔍 Hint

Who is using that service?

alice

✓ Correct Answer

🔍 Hint

What's the hostname the requests are sent to?

www.server.bob

✓ Correct Answer

Which file is being requested?

test.txt ✓ Correct Answer

What text is in the file?

OK ✓ Correct Answer Hint

Which credentials are being used for authentication? (username:password)

admin:s3cr3t_P4zz ✓ Correct Answer Hint

Now, stop the attack (by pressing q). What is ettercap doing in order to leave its man-in-the-middle position gracefully and undo the poisoning?

RE-ARPing the victims ✓ Correct Answer Hint

Can you access the content behind that service, now, using the obtained credentials? (Yay/Yay)

Yay ✓ Correct Answer Hint

What is the user.txt flag?

THM{wh0s_\$n!ff1ng_0ur_cr3ds} ✓ Correct Answer

You should also have seen some rather questionable kind of traffic. What kind of remote access (shell) does Alice have on the server?

reverse shell ✓ Correct Answer Hint

What commands are being executed? Answer in the order they are being executed.

whoami, pwd, ls ✓ Correct Answer

Which of the listed files do you want?

root.txt ✓ Correct Answer Hint

Task 8: Man-in-the-Middle: Manipulation

What is the root.txt flag?

THM{wh4t_an_ev1l_M!tM_u_R} ✓ Correct Answer

Task 9: Conclusion

Answer the questions below

Read the above.

No answer needed ✓ Correct Answer